SEN381 — SOFTWARE ENGINEERING 381

CivicConnect

Project Engineering Document (PED) v3.0

Milestone 3 — Controlled Construction, Integration, Quality & Release Readiness

Submission information	Detail
Team	Runtime Terrors — Nhlavutelo Shiviri (602944), Frontend · Tsholofelo Lephondo (602745), Backend · Rethabile Ledidi (601910), Database
GitHub repository	https://github.com/rethabileledidi/CivicConnect_Runtime-Terrors
M3 release candidate	Commit 52c57cc on main (10 Oct 2026). The PED, RTM, evidence and demonstration all refer to this commit.
PED version	v3.0 (continues PED v1.0 and v2.0; history preserved in Section 0)
RTM location	Appendix A.1 of this PED
CI and test evidence	https://github.com/rethabileledidi/CivicConnect_Runtime-Terrors/actions — CI run #8 and CodeQL Advanced run #1 on 52c57cc (both green)
Staging / test environment	Simulated staging on a team laptop (Section 8.2), demonstrated live in the presentation
Stack	React 19 · Java 21 REST API on Tomcat 10.1 · PostgreSQL 16
Date submitted	As recorded by the Moodle submission
Referencing	Harvard

PED v3.0 continues PED v2.0. Sections 1–10 follow the M3 evidence index (SEN381, 2026b). Sections 11–12 answer the M2 feedback on data and technology. Appendix A continues the project registers; Appendix B holds the performance-test scripts. Content that did not change in M3 (stakeholders, scope rationale, architecture, API, UI and security design) remains in PED v2.0 and is not repeated here.

Contents

0. Document Control and M2 Feedback....3
1. M3 Overview....3
2. M2 Baseline Conformance....3
3. Controlled Changes....4
4. Construction and Configuration....4
5. CI and Automated Verification....5
6. Quality Strategy Applied....5
7. Black-box, Integration and System Validation....6
8. Performance, Reliability and Staging....8
9. Defects and Quality Interpretation....8
10. Release Readiness....9
11. Data and Persistence (feedback G2)....10
12. Technology Stack (feedback G3)....11
Appendix A. Continued Project Registers....13
Appendix B. PT-01 Scripts....15
References....16

0. Document Control and M2 Feedback

Version	Date	Summary	Status
1.0	2026-09-09	M1 baseline: problem, stakeholders, scope, requirements, RTM, risks	Baselined
2.0	2026-09-30	M2: architecture, stack, data model, design decisions, API, security, ADRs	Baselined
3.0	2026-10-11	M3 evidence index; M2 feedback G1–G3; CR-06 to CR-10; test, CI, performance and restore evidence; registers continued	Submitted for M3

ID	M2 feedback	Response	Where
G1	GitHub link gives errors.	v2.0 pointed to branch integration/m2-final, deleted after merging, and printed the address without https://. v3.0 gives the full public URL and names the assessed commit.	Cover
G2	Data: more evidence for choices; add field sizes and reasoning.	Section 11 justifies the model, keys, every important field size, constraints, indexes and storage, and measures the estimate.	Section 11
G3	Tech stack: compare with other technologies and versions in detail.	Section 12 scores each layer against alternatives and compares older and newer versions of each chosen product.	Section 12

1. M3 Overview

The release candidate is commit 52c57cc on main. It builds and passes all 68 automated tests in CI run #8. Scope was frozen at the start of M3; two partly built Must requirements were moved to M4 through CR-08 rather than dropped silently.

Capability	Requirements	State
Register, sign in, lockout	NFR-02, NFR-10	Implemented
Submit request; reference number; track status and history	FR-01–04, FR-06	Implemented
Work queue; assign, start, resolve, close, reopen	FR-05, 07, 08, 10; NFR-06	Implemented
Append-only audit history	NFR-03	Implemented
Management dashboard, reports, CSV export	FR-05, FR-11	Implemented
In-app notifications; simulated SMS/WhatsApp	FR-13	Implemented
Free-standing staff comments	FR-09 (part)	Deferred — L-01
Restricted-category flag	FR-12 (part)	Deferred — L-02

2. M2 Baseline Conformance

M2 decision	Evidence at 52c57cc	Conformance
Layered monolith, REST API (ADR-01)	Packages api → service → lifecycle → data; only repositories run SQL	As planned
React 19 · Java 21 · Tomcat 10.1 · PostgreSQL 16 (ADR-02)	package.json, pom.xml, CI image postgres:16	As planned
State pattern for the lifecycle (ADR-04)	RequestStates.java; all 42 status pairs tested	As planned
Audit row in the same transaction; notifications as observers (ADR-05)	Deferred trigger; failing-listener test	As planned
Optimistic concurrency (ADR-06)	UPDATE … WHERE version = ?; stale-update tests	As planned

M2 decision	Evidence at 52c57cc	Conformance
Integration branch integration/m2-final	Merged and deleted; main is the baseline	Changed — CR-06
CI = build and tests only (ADR-09)	CodeQL added; lint and dependency review proposed in PR #4	Partly changed — CR-07

3. Controlled Changes

Each change followed Change Request → Impact Analysis → Decision → Update Baseline (SEN381, 2026a). CR-01 to CR-05 are recorded in PED v2.0.

CR	Problem and evidence	Revised decision	Consequence
CR-06	Integration branch deleted after merge; PED link broke (G1)	main is the single baseline; release candidate identified by commit hash	Assessor link fixed
CR-07	M3 requires a static check and a security check (SEN381, 2026b)	CodeQL workflow (Java, TypeScript, Actions); dependency review and ESLint proposed in PR #4; manual secret scan	CodeQL green on the RC
CR-08	Scope freeze; verification took priority	FR-09 comments and FR-12 category flag moved to M4	RTM rows Partial; RR-03
CR-09	Staging had no defined separation from development	Simulated staging with its own database, credentials and RC build (ADR-13)	Release identity verifiable
CR-10	Repository is owned by a personal account; only the owner can change Settings and was unavailable	Review and CI rules run as a written team agreement; every bypass logged	Not enforced by GitHub; RR-06

4. Construction and Configuration

- **Repository:** one repository for frontend, backend, SQL migrations V0–V6, ADRs and the PED, so one commit identifies everything assessed. Work is done on short-lived branches and merged by pull request (PRs #2 and #3 merged; #4 open).
- **Team rule:** two approvals from the other members and green CI before merging; the PR template asks for the requirement/ADR trace and a reviewer checklist (bound SQL parameters, no secrets, schema approved by the database owner).
- **Implementation:** lifecycle rules live only in lifecycle/; the frontend shows only the actions the API allows; migrations are additive, so the previous build still runs on the new schema (basis of rollback).

Deviations (CR-10)

Branch protection cannot be switched on by collaborators, so the rule above is not enforced by GitHub. Bypasses are recorded rather than hidden:

ID	Date	What happened	Handling
DEV-01	30 Sep	PR #3 merged while its CI check was red (CI #1); main stayed red (CI #2, #3)	Root cause fixed 7 Oct (DF-01); green from CI #4
DEV-02	7 Oct	Five commits pushed directly to main (68a640e … 5f07f32)	Each re-checked by CI on main
DEV-03	10 Oct	CodeQL workflow committed directly via GitHub's setup page (52c57cc)	Workflow reviewed in Section 5

Configuration and secrets

Item	Control and evidence
Database credentials	Kept out of source code: Tomcat reads environment variables; context.xml uses ${…}; .env.example holds names only; .env is git-ignored. OWASP (2026) rates environment variables below a secrets manager — acceptable for local staging, revisit with hosting at M4

Item	Control and evidence
Database roles	civic_owner (DDL) and civic_app (SELECT, INSERT, UPDATE only); passwords supplied at run time to V0
Dev-only data	Demo logins only in V6; dev auto-login off in context.xml
Secret scan	GitHub secret scanning is an owner setting (CR-10). Manual scan of the working tree and full history on 10 Oct: no secrets, only documented placeholders

5. CI and Automated Verification

Two GitHub Actions workflows run on every pull request and push to main.

Workflow / job	What it checks	Status at RC
CI — backend	JDK 21; mvn verify runs 54 unit and 14 database tests against a disposable PostgreSQL 16; applies migrations V1–V6	Green (CI #8)
CI — frontend	Locked install; TypeScript type-check and Vite build	Green (CI #8)
CodeQL Advanced	Security analysis of Java, TypeScript and workflow files; also weekly (GitHub, 2026a)	Green (run #1)
Dependency review, ESLint	Block new high-severity dependencies; lint as warning (GitHub, 2026b)	Proposed in PR #4 — not in RC

Gate evidence. CI #1 failed on PR #3 and the PR was merged anyway (DEV-01); CI #2 and #3 stayed red. The failures were investigated, not re-run: the test database lacked V5/V6 (68a640e) and trigger functions used an unpinned search_path (ac5de97, DF-01). Every run since CI #4 is green. This is the main argument for CR-10: a gate that is only agreed was ignored once under pressure.

What a green pipeline does not prove: that FR-09/FR-12 are complete, that UI journeys work, that response times are met, or that untested inputs behave correctly. Coverage percentage is not used as a gate; Section 7 states which behaviours are tested.

6. Quality Strategy Applied

Verification depth followed likelihood and impact of failure (Lephondo, Shiviri and Ledidi, 2026).

Risk	L / I	Evidence chosen
Illegal status change or missing audit row (FR-08, NFR-03)	M / H	Three levels: State classes (all 42 pairs), service rejects before the database, PostgreSQL rejects at commit; plus E2E
Broken access control (FR-12, NFR-02) — OWASP A01 (OWASP, 2025)	M / H	Decision-table tests per role; another resident's request returns 404
Lost update (ADR-06)	L / H	Service test (409) and database test (nothing written)
Credential attack (NFR-10)	M / H	Boundary tests on length and lockout; identical error for unknown user and wrong password
Slow queue or submit (NFR-01, NFR-09)	M / M	PT-01 load test on 10,000 requests

7. Black-box, Integration and System Validation

Techniques: **state transition** (lifecycle), **decision table** (who may do each move), **boundary value analysis** (lengths, counts, ratings) and **equivalence partitioning** (submission input). Expected results come from the M1 acceptance criteria and M2 ADRs. TC-01 to TC-21 are automated and pass in CI #8; TC-22 and TC-23 are run manually in the live demonstration.

ID	Test (class.method)	Level	Technique	Expected result	Req.
TC-01	RequestLifecycleTest.everyPairIsEitherLegalOrRefused	Unit	State transition	8 of 42 status pairs legal; 34 refused	FR-08, NFR-06
TC-02	RequestLifecycleTest.onlyOversightCanAssign; onlyTheAssigneeCanStartAndResolve	Unit	Decision table	Only permitted roles succeed	FR-07, FR-12
TC-03	RequestLifecycleTest.resolvingNeedsResolutionNotes; rejectingNeedsANote	Unit	EP	Missing or blank notes refused	FR-10
TC-04	RequestServiceTest.illegalMovesNeverReachTheRepository	Component	Negative	422; repository never called	FR-08
TC-05	RequestServiceTest.residentsCannotSeeOtherResidentsRequests_andGetNotFoundNotForbidden	Component	Unauthorised	404 for other resident and unassigned staff	FR-12, NFR-02
TC-06	RequestServiceTest.staleVersionBecomesAConflictThatAsksTheUserToReload	Component	Negative	409 'reload'	FR-08
TC-07	RequestServiceTest.aFailingListenerDoesNotUndoTheStatusChange	Component	Failure injection	Status change still committed	FR-13
TC-08	RequestServiceTest.submitValidatesEveryFieldServerSide	Component	EP (invalid classes)	Error for all 8 invalid fields; nothing stored	FR-01
TC-09	AuthServiceTest.shortPasswordsAndMismatchesAreRejectedWithFieldErrors	Unit	BVA	14-character password rejected	NFR-10
TC-10	AuthServiceTest.fiveFailuresLockTheAccountForFifteenMinutes	Unit	BVA; state	Locked on 5th failure; unlocked after 15 min	NFR-10
TC-11	AuthServiceTest.unknownEmailAndWrongPasswordGiveTheSameMessage	Unit	Negative	Identical message	NFR-02
TC-12	RequestServiceTest.feedbackOnlyByRequesterOnceResolved_andOnlyOnce	Component	BVA; negative	Rating 9 rejected; second rating 409	FR-13
TC-13	OutboxDispatcherTest.failuresAreRetriedThenMarkedFailedAfterThreeAttempts	Unit	BVA; state	FAILED after exactly 3 attempts	FR-13
TC-14	RequestQueryBuilderTest.unknownSortFallsBackToCreated…; searchTextIsBoundAsParameter…	Unit	Negative (injection)	Injected sort ignored; text bound	FR-05
TC-15	RequestQueryBuilderTest.pageSizeIsCapped; createdToIsInclusiveOfTheWholeDay	Unit	BVA	Page size capped; last day included	FR-05

ID	Test (class.method)	Level	Technique	Expected result	Req.
TC-16	CsvWriterTest.neutralisesSpreadsheetFormulas	Unit	Negative	Cells starting =, +, @ neutralised	FR-11
TC-17	JdbcServiceRequestRepositoryDbTest.statusChangeUpdatesRequestAndHistoryAtomically	Integration (DB)	Integration	Request and history written together	FR-08, NFR-03
TC-18	JdbcServiceRequestRepositoryDbTest.staleVersionIsRejectedAndNothingIsWritten	Integration (DB)	Negative	Second update rejected, no partial write	FR-08
TC-19	JdbcServiceRequestRepositoryDbTest.statusChangeWithoutHistoryIsRejectedAtCommit; historyCannotBeEdited	Integration (DB)	Negative	Commit rolled back; history edit refused	NFR-03
TC-20	JdbcServiceRequestRepositoryDbTest.databaseRejectsAssignmentWithoutAssigneeAndRollsBack	Integration (DB)	Negative	CHECK violation; rollback	FR-07
TC-21	ReportConsistencyDbTest.reportCountsMatchDashboardTiles	Integration (DB)	Acceptance	Report counts equal dashboard and records	FR-11
TC-22	E2E-1: resident signs in, reports a water leak, sees it on My dashboard	System / E2E	Acceptance	Reference number shown; status Submitted	FR-01–04
TC-23	E2E-2: coordinator assigns, staff starts and resolves, resident closes	System / E2E	Acceptance; state	Only allowed buttons per role; 5 attributed history rows	FR-06–08, 10, 13

Minimum baseline (SEN381, 2026b): unit/component 16 (TC-01–16) · black-box functional 10 · API/integration 5 (TC-17–21) · E2E 2 (TC-22–23) · negative/unauthorised 12 · four black-box techniques.

Interpretation. FR-08/NFR-03 has the strongest evidence: the rule is checked in the State classes, the service and the database, so a defect would have to pass all three. FR-12 is weakest because the restricted-category flag does not exist (L-02). Known gaps: some boundaries are tested on one side only (DF-03), and there are no automated HTTP-level tests (TD-06).

8. Performance, Reliability and Staging

8.1 Performance test PT-01 (executed 11 Oct 2026)

Item	Design and result
Operation	The real SQL behind the staff work queue (JdbcRequestQueries.listOpenQueue) and request submission (request + first history row in one transaction)
Why	The queue is the heaviest read and loads on every staff page; submission is the requester's first impression
Target	Queue p95 ≤ 1.0 s (NFR-09), submit p95 ≤ 2.0 s (NFR-01), errors < 1% (Nielsen, 2024)
Set-up	pgbench (PostgreSQL Global Development Group, 2026d) as the least-privilege app role; 2 vCPU, 7 GB RAM, PostgreSQL 16.15; 10,000 requests and 19,415 history rows (16 MB)
Workload	10 concurrent clients for 120 s, 4 queue reads per submit, no think time — well above the ~50 requests a day expected (A-M2-03)
Result	Queue: 10,239 runs, p95 161 ms, max 223 ms. Submit: 2,603 runs, p95 44 ms, max 90 ms. 0 errors. Every request still matched its latest history row

Interpretation. At the database tier both operations use a small part of their budget (16% and 2%). The queue query scans every request because 'open' is decided through a join, so its time will grow with data (TD-08). **Not proven:** the full round trip through Tomcat and the browser, a cloud host, municipal-scale data or a cold start (RR-01). Scripts: Appendix B.

8.2 Simulated staging and recovery

Aspect	Development	Staging
Code	Working tree, Vite dev server	WAR built from 52c57cc; frontend run from the same commit on the Vite server, because the production build targets Cloudflare and has no route to the Java API
Database	civicconnect with demo data	civicconnect_staging with its own civic_staging login
Release check	—	/api/health = UP; git log -1 shows 52c57cc at the start of the demo

Restore test (11 Oct). The 10,000-request database was backed up with pg_dump and restored into an empty database: identical counts (12,603 requests / 22,018 history rows / 43 users), identical report checksum, and the append-only trigger still refused edits. **Rollback** is redeploying the previous WAR; migrations are additive, so no schema downgrade is needed.

9. Defects and Quality Interpretation

This is the controlled Defect Register.

ID	Defect / finding	Sev.	Status	Implication
DF-01	Trigger functions used an unpinned search_path; DB tests failed in CI	High	Fixed (ac5de97)	CI #4–#8 green; covered by TC-17–21
DF-02	Long text columns have no database length limit (service caps at 2,000)	Low	Open → TD-02	Only a direct SQL client could exceed it
DF-03	Boundaries tested on one side only (title 150/151, password 15, rating 0/6)	Low	Open → M4	Rules exist; edges untested
DF-04	Health endpoint does not report the build version	Low	Open → TD-04	RC shown with git log instead

ID	Defect / finding	Sev.	Status	Implication
PROC-01	Merge on red and direct commits to main (DEV-01–03)	Med.	Open — CR-10	Rules depend on team discipline (RR-06)

Interpretation. 68 automated tests pass, but this measures how deeply the built rules are tested, not how complete the product is: FR-09 comments and the FR-12 flag have no tests because they do not exist yet.

10. Release Readiness

Evidence area	Result	Interpretation
Build and CI	Pass (CI #8)	Green on main since 7 Oct
Automated regression	68/68	Lifecycle, access, auth, concurrency, reporting
Integration (DB)	5/5	Real PostgreSQL 16; no HTTP-level tests (TD-06)
System / E2E	Live demo	TC-22, TC-23 on simulated staging
Static / security	Pass	CodeQL #1; manual secret scan clean
Performance	Pass (DB tier)	p95 161 ms / 44 ms, 0 errors
Backup / restore	Pass	Restored and verified
Governance	Not enforced	Team agreement; 3 deviations (CR-10)
Acceptance	Partial	All Must criteria evidenced except FR-09 comments and FR-12 flag

Classification: CONDITIONALLY READY. Core lifecycle, audit, access and reporting are verified at several levels, performance has large headroom at the database, a backup was restored, and no high-severity defect is open. It is not READY because FR-09 and FR-12 are only partly built, the E2E journeys are manual, and review/CI rules are not enforced by GitHub. If either E2E journey fails in the demonstration, the classification becomes NOT READY.

ID	Residual risk	Mitigation	Next action
RR-01	Full-stack load untested	PT-01 headroom; indexes	Re-test on M4 host
RR-02	HTTP only, single host	Config by environment variables	HTTPS + Secure cookie at M4
RR-03	Sensitive requests visible to coordinators	Staff see only assigned requests	FR-12 flag in M4
RR-04	Single PostgreSQL instance	Tested pg_dump restore	Managed backups at M4
RR-06	Unreviewed change reaches main	Agreement; deviation log; RC fixed by hash	Owner enables protection

11. Data and Persistence (feedback G2)

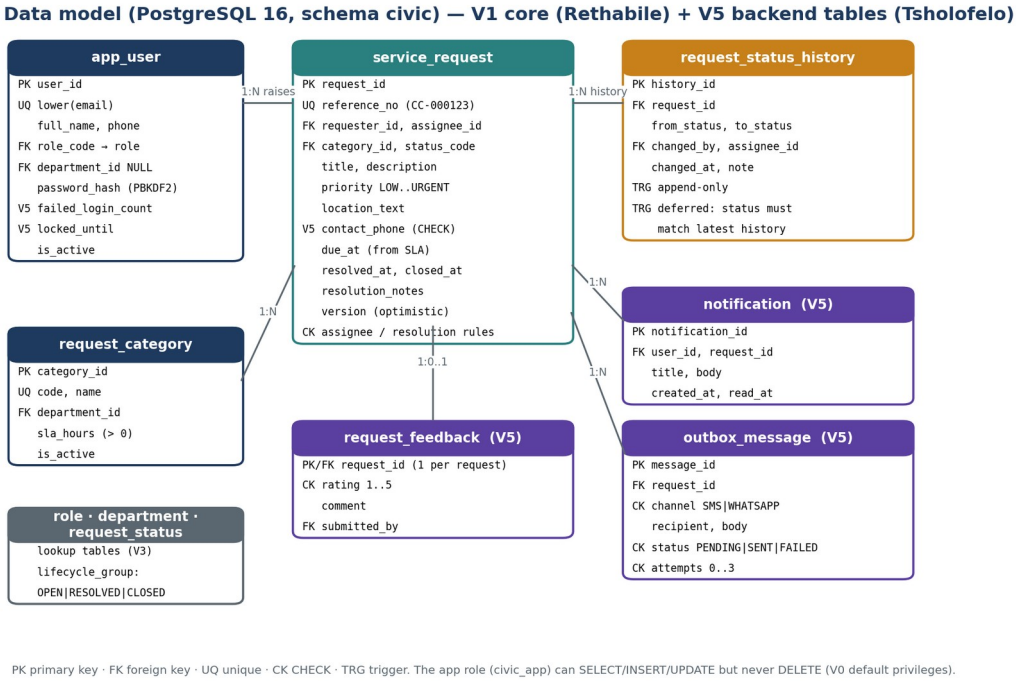


Figure 1 — Schema civic (V1 core, V3 lookups, V5 backend tables).

11.1 Why a relational model

Every history row must belong to an existing request and user (NFR-03); status and history must change together (ADR-05); and management reports group requests by status, category and department (FR-11). Foreign keys, multi-table ACID transactions, CHECK constraints and GROUP BY give these directly. A document store would need the application to enforce references and would make cross-request reports harder. Volume (~18,250 requests a year) needs no horizontal scaling.

11.2 Key design choices

Choice	Reason
Statuses and categories as lookup tables	They carry attributes (lifecycle group; SLA hours, department). Small fixed sets (priority, channel) use CHECK. ENUM types were rejected because values cannot be removed (PostgreSQL Global Development Group, 2026c)
BIGINT identity keys	SQL-standard; GENERATED ALWAYS blocks hand-typed ids. UUIDs were rejected: unreadable for residents, and id-guessing is already stopped by the 404 rule (TC-05). SMALLINT for the 9 categories
reference_no stored generated column	Unique, indexed and searchable as CC-000123 without recomputing
due_at copied at creation	Changing an SLA later must not re-label old requests as overdue
TIMESTAMPTZ everywhere	Instants in UTC; laptops and UTC CI runners agree on 'overdue'

11.3 Field sizes

In PostgreSQL, VARCHAR(n) and TEXT are stored identically; n is a validation limit, not reserved space (PostgreSQL Global Development Group, 2026b). Limits therefore follow what valid data looks like, and each is mirrored by the service-layer validator so users get a field error first.

Column	Type / size	Reason
service_request.title	VARCHAR(150)	Service requires 5–150 characters: enough for a full street description, short enough for one queue row and a 150-character notification title
service_request.description	TEXT	Service requires 20–2,000; database cap still missing (TD-02)
service_request.location_text	VARCHAR(255)	Address ≤150 + suburb ≤60 + city ≤40 + separators = 254
service_request.contact_phone	VARCHAR(20), CHECK ^0[0-9]{9}$	Optional (POPIA minimality); exactly a 10-digit SA number
service_request.reference_no	VARCHAR(20)	Uses 9 characters; lpad to 6 digits collides after request 999,999 (TD-03)
service_request.priority / status_code	VARCHAR(10) / (20)	Longest values URGENT (6) and IN_PROGRESS (11)
service_request.version	INTEGER	Concurrency counter; a request changes a handful of times
app_user.email	VARCHAR(254), unique on lower(email)	A full email address is limited to 254 characters (Auth0, 2025); case-insensitive duplicates rejected
app_user.full_name	VARCHAR(120)	Several given names and double-barrelled surnames without truncation
app_user.phone	VARCHAR(20)	International E.164 numbers have at most 15 digits (Twilio, 2026b)
app_user.password_hash	VARCHAR(255)	pbkdf2_sha256$600000$salt$hash = 90 characters; room to raise iterations without a migration
history.changed_at	TIMESTAMPTZ, clock_timestamp()	now() is fixed per transaction and would tie two rows; clock_timestamp() gives real order
outbox_message.body	VARCHAR(500)	An SMS segment is 153–160 characters (Twilio, 2026a); 500 caps cost at four segments
request_feedback.rating	SMALLINT CHECK 1–5	Star rating; request_id is the primary key so a second rating is impossible

11.4 Integrity, indexes and capacity

- **Defence in depth:** each rule is enforced in the UI, the service and the database — e.g. legal moves (State classes + status FK + commit-time history check), assignee when assigned (validator + CHECK), no lost updates (409 + version check).
- **Indexes** follow the reads: status, category × status, newest first, assignee (partial), requester, and a partial index on due_at for open requests only, so it stays small as closed history grows.
- **Least privilege:** the app role has no DELETE or DDL; history is append-only by trigger.
- **Capacity:** estimated ≈ 4 KB per request with history, notifications and indexes → ≈ 73 MB a year at 50 a day. PT-01 measured 16 MB for 10,000 requests (without notifications), so the estimate is conservative.

12. Technology Stack (feedback G3)

Candidates had to be free and able to enforce the Must rules on the server. They were then scored 1–5 on: team capability (25), requirement fit (20), support and licence (15), testability/CI (15), fit with modules already built (15) and ecosystem (10). Totals are out of 500.

12.1 Alternatives per layer

Layer	Chosen	Alt. 1	Alt. 2	Alt. 3	Alt. 4
Frontend	React 19 — 465	Vue 3.5 — 345	JSP only — 345	Angular 20 — 320	Svelte 5 — 295

Layer	Chosen	Alt. 1	Alt. 2	Alt. 3	Alt. 4
Backend	Java 21 — 500	C#/.NET 8 — 400	Node.js 22 — 340	Python/Django — 305	Go — 270

- **React** won mainly because the frontend already existed and its owner can defend it; SPA frameworks were otherwise close. A JSP-only UI would reload the page on every action, working against NFR-08's 0.2 s feedback.
- **Java** fits the team and reuses the reporting module; the JDK provides PBKDF2 for NFR-10 with no extra library. .NET matched it on requirement fit and would have won had the reporting module not already been Java.

Database capability needed	PostgreSQL 16	MySQL 8.4	SQL Server Express	SQLite	MongoDB
Check status + history at commit (ADR-05)	Yes	No	No	Partly	No
Partial indexes	Yes	No	Filtered	Yes	Yes
Roles and GRANT (no DELETE)	Yes	Yes	Yes	No	Yes
Transactional DDL	Yes	No	Yes	Yes	n/a
Free size limit	None	None	10–50 GB (Microsoft, 2025)	None	None

PostgreSQL is the only engine that can refuse, at commit, a status with no matching history row, which is the database backstop for the audit requirement.

12.2 Version comparisons

Product	Older version	Chosen version	Newer version
Java	17: Oracle Premier Support ended Sept 2026 — rejected	21 LTS: Premier to Sept 2028; virtual threads; free Temurin builds (Oracle, 2026; Adoptium, 2026)	25 LTS: weeks old when the stack was fixed; upgrade at M4 (D-10)
Tomcat	9: old javax packages; support ends 31 Mar 2027 (Apache Software Foundation, 2026)	10.1: Jakarta Servlet 6.0, supported; reporting module already ran on it	11: Servlet 6.1 features not needed
PostgreSQL	—	16: every feature used is present; supported to Nov 2028 (PostgreSQL Global Development Group, 2026a)	17/18: no needed feature; upgrade with hosting at M4
React	18: older form handling; libraries moving on	19.2: Actions for form pending/error state; ref as a prop (React, 2024)	—
pgjdbc driver	42.7.4–42.7.6: CVE-2025-49146	42.7.7: includes the fix (National Vulnerability Database, 2025)	—

12.3 Supporting choices

Concern	Chosen	Main alternative and why not
JDK build	Eclipse Temurin 21	Oracle JDK 21 moves to the OTN licence from the October 2026 update (Oracle, 2026)
Web framework	Plain Jakarta Servlets	Spring Boot: a second framework mid-project that the team would have to learn and defend
Data access	JDBC behind repositories	JPA/Hibernate hides the SQL and makes the commit-time trigger harder to reason about
Build and styling	Vite 8 · Tailwind CSS 4	Create React App was deprecated in Feb 2025 (React, 2025); Tailwind 3 has a slower engine (Tailwind Labs, 2025)

Appendix A. Continued Project Registers

The registers continue from PED v2.0. Unchanged entries are in PED v2.0 and are not repeated.

A.1 Requirements Traceability Matrix v3.0

Req	Acceptance criterion	Implementation	Tests	Execution evidence	Status
FR-01/02	Request stored; reference shown before leaving page	RequestService.submit; reference_no	TC-08, 17, 22	CI #8; live demo	Verified
FR-03/04	Own requests only, current status	scope=mine; AccessPolicy	TC-05, 22	CI #8; live demo	Verified
FR-05	Filter and sort return only matching rows	RequestQueryBuilder	TC-14, 15, 21	CI #8	Verified
FR-06	Detail with ordered, attributed history	RequestService.detail	TC-17, 23	CI #8; live demo	Verified
FR-07	Single assignee; only coordinator assigns	RequestStates; CHECK	TC-02, 20, 23	CI #8; live demo	Verified
FR-08	Skipped transitions rejected	lifecycle/*; deferred trigger	TC-01, 04, 06, 17–19, 23	CI #8; live demo	Verified
FR-09	Timestamped comments	Notes on transitions only	TC-03	CI #8	Partial — L-01
FR-10	Resolution notes required	needsResolutionNotes; CHECK	TC-03, 23	CI #8; live demo	Verified
FR-11	Counts match records	Reporting views	TC-16, 21	CI #8	Verified
FR-12	Unauthorised staff denied sensitive requests	AccessPolicy	TC-02, 05	CI #8	Partial — L-02
FR-13	Requester notified; failure isolated	Observer; outbox	TC-07, 12, 13, 23	CI #8; live demo	Verified
NFR-01/09	p95 ≤ 2.0 s / 1.0 s	Indexes; one call per action	PT-01	pgbench, 11 Oct	Met at DB tier
NFR-02/10	Authentication; password policy; lockout	auth/*; ApiSecurityFilter	TC-05, 09–11	CI #8	Verified
NFR-03/06	History immutable; rules consistent	Triggers; State classes	TC-01, 19	CI #8	Verified

A.2 Decisions and ADRs (new in M3)

ID	Decision	Status
ADR-12	Static and supply-chain checks: CodeQL workflow; dependency review and ESLint (warning) in PR #4; manual secret scan	CodeQL in RC; rest proposed
ADR-13	Simulated staging with separate database, credentials and RC build	Accepted
D-13	Release candidate identified by commit hash 52c57cc	Closed
D-15	pgbench for PT-01 (ships with PostgreSQL; measures the database tier)	Closed
D-17	Review and CI rules as a team agreement until the owner enables branch protection	Open — CR-10
D-08 / D-10 / D-12	Production hosting; Java 25; FR-12 restricted flag	Open — M4

A.3 Risk Register (changed entries)

ID	Risk	P / I	Mitigation / evidence	Status
R-04	Security as an afterthought	L / C	Each control has a test; CodeQL	Mitigated
R-08	Oracle JDK 21 licence change	M / M	Temurin 21	Closed
R-18	Integration regressions	M / H	CI on every push and PR	Mitigated
R-19	FR-12 flag missing	M / M	Deferred (CR-08)	Accepted
R-20	Changes bypass review	H / H	Happened 3 times; deviation log	Active → RR-06
R-22	Performance target missed on real host	M / M	PT-01 baseline	Active → RR-01

A.4 Technical Debt Register

ID	Debt	Plan
TD-01	FR-09 comments and FR-12 flag not built	M4 sprint 1
TD-02	No database length cap on long text columns	CHECK constraints in V7
TD-03	reference_no collides after request 999,999	Widen to 8 digits in V7
TD-04	Health endpoint lacks build version	Read from the WAR manifest
TD-06	No automated HTTP-level API tests	Add in M4
TD-07	Secure cookie flag off (HTTP staging)	Enable with HTTPS at M4
TD-08	Open-queue query scans all requests (PT-01)	Filter on status_code or paginate

A.5 AI Usage Register

Policy D-05 is unchanged: AI output is a draft that the owning member reads, tests and can explain without the tool. The register continues from PED v2.0.

Member	Tool	Milestone	Used for	Verification
N. Shiviri	Lovable	M2	Scaffolding UI components and page layouts	Pages reviewed and adapted; wired to the API; no business rules or secrets in the browser
R. Ledidi	AI assistant	M2	Drafting SQL, Java and ADR wording from the team's A2 research	All scripts run on PostgreSQL 16; covered by unit and database tests
T. Lephondo	Claude	M2	Troubleshooting backend code and tests; compiling presentation slides	Compiled and unit-tested; SQL run as the app role; integrated and smoke-tested; sources checked

Member	Tool	Milestone	Used for	Verification
T. Lephondo	Claude	M3	Drafting PED v3.0 from the repository and A2/A3 research; running PT-01 and the restore test (Appendix B); drafting the M3 slides and script	Claims checked against commit 52c57cc; test names checked in src/test; PT-01 uses SQL copied from the application; version and support dates checked against vendor pages; claims that could not be evidenced were removed

Appendix B. PT-01 Scripts

Run only against a copy of the database. queue.sql is the exact SQL of JdbcRequestQueries.listOpenQueue (coordinator view); submit.sql is the two statements of JdbcServiceRequestRepository.create.

queue.sql

```
SELECT request_id, reference_no, title, description, priority, location_text,
       status_code, status_name, lifecycle_group, category_id, category_name, department_name,
       requester_id, requester_name, assignee_id, assignee_name,
       created_at, updated_at, due_at, resolved_at, closed_at, version,
       is_overdue, overdue_hours, age_days, resolution_hours, resolved_within_sla
  FROM civic.v_request_overview
 WHERE lifecycle_group = 'OPEN'
   AND (CAST(NULL AS BIGINT) IS NULL)
   AND (CAST(NULL AS VARCHAR) IS NULL)
 ORDER BY is_overdue DESC, due_at, request_id
 LIMIT 200;
```

submit.sql

```
\set rid random(14, 43)
\set cat random(1, 9)
BEGIN;
INSERT INTO civic.service_request (title, description, category_id, priority, requester_id,
location_text)
VALUES ('PT-01 burst pipe', 'Synthetic request created by the PT-01 load test; no real personal data.',
:cat, 'MEDIUM', :rid, '12 Church Street, Hatfield, Pretoria')
RETURNING request_id AS new_id \gset
INSERT INTO civic.request_status_history (request_id, from_status, to_status, changed_by, assignee_id,
note)
VALUES (:new_id, NULL, 'SUBMITTED', :rid, NULL, 'Request logged');
COMMIT;
```

Command

```
pgbench -h localhost -U civic_app -d civicconnect -n -M prepared -c 10 -j 2 -T 120 \
        -f queue.sql@4 -f submit.sql@1 -l --log-prefix=pt01
```

References

Adoptium (2026) *Support — Temurin release roadmap*. Eclipse Foundation.

Apache Software Foundation (2026) *Apache Tomcat 9.0.x end of support announcement*. Apache Tomcat project.

Auth0 (2025) *Email length limits and validation*. Auth0 Support Center, updated 10 September.

GitHub (2026a) *About code scanning with CodeQL*. GitHub Docs.

GitHub (2026b) *About dependency review*. GitHub Docs.

Lephondo, T., Shiviri, N. and Ledidi, R. (2026) *SEN381 Assignment 3: quality strategy, security and production readiness*. Unpublished team submission.

Microsoft (2025) *Editions and supported features of SQL Server 2025*. Microsoft Learn.

National Vulnerability Database (2025) *CVE-2025-49146: PostgreSQL JDBC driver channel binding requirement bypass*. Gaithersburg: National Institute of Standards and Technology.

Nielsen, J. (2024) *Response time limits*. Nielsen Norman Group.

Oracle (2026) *Oracle Java SE support roadmap*. Austin: Oracle Corporation.

OWASP (2025) *OWASP Top 10:2025*. OWASP Foundation.

OWASP (2026) *Secrets management cheat sheet*. OWASP Cheat Sheet Series.

PostgreSQL Global Development Group (2026a) *Versioning policy*. PostgreSQL.

PostgreSQL Global Development Group (2026b) 'Character types', *PostgreSQL 16 documentation*.

PostgreSQL Global Development Group (2026c) 'Enumerated types', *PostgreSQL 16 documentation*.

PostgreSQL Global Development Group (2026d) 'pgbench', *PostgreSQL 16 documentation*.

React (2024) 'React v19', *React Blog*, 5 December.

React (2025) 'Sunsetting Create React App', *React Blog*, 14 February.

SEN381 (2026a) *CivicConnect Master Project Brief, v1.1*. Software Engineering 381, Belgium Campus ITversity.

SEN381 (2026b) *CivicConnect Milestone 3: controlled construction, integration, quality & release readiness*. Software Engineering 381, Belgium Campus ITversity.

Tailwind Labs (2025) 'Tailwind CSS v4.0', *Tailwind CSS Blog*, 22 January.

Twilio (2026a) *What the heck is a segment?* Twilio Help Center.

Twilio (2026b) *What is E.164?* Twilio Docs glossary.